Flosum Scan Integration

PDF ⤓

Flosum Scan is an app designed to scan all types of code present in a Salesforce org. Flosum Scan leverages SonarQube's trusted platform to meet high code quality standards, enhanced security and quickly find vulnerabilities. SonarQube is a Clean Code solution that can be deployed on-premises or in the cloud. It helps detect and address code errors early in the software development lifecycle, preventing costly and time-consuming fixes later on. By integrating Flosum Scan with your DevOps process, you ensures high code quality standards are met consistently across all projects and throughout every stage of the workflow.

You can connect either to Flosum's default SonarQube instance or your own.

For a list of all supported Flosum Scan rules, see Flosum Scan Rules.

Note: It's important to note that this package is compatible with **Flosum DevOps package version 3.243 or higher.**

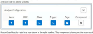
Prerequisites

Install the Flosum Scan managed package on the same Salesforce org as your Flosum DevOps. After package installation, complete the post-installation steps.

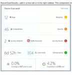
Post-installation Steps

Add the following Lightning components to your branch:

- branchSync—add in the right-navigation pane. Use this to decide what component types to scan from the branch. You can also add this component to a Branch tab for added visibility.



- flosumScanResults—add in a new tab or in the right sidebar. This component shows you the scan results for that particular branch.


Flosum Scan result — View issues

12 Bugs — Reliability

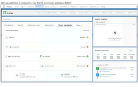
46 Vulnerabilities — Security

2 Security Hotspots — 0.0% Reviewed — Security Review

6d 52h Debt — 304 Code smells — Maintainability

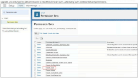
0.0% Coverage on 517 Lines to cover — 4.2% Duplications on 2.9k Lines

After you add these 2 components, your branch screen now appears as follows:



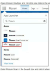
Assign Flosum Scan Permissions

If this is the first time you are installing Flosum Scan, assign the "Flosum Scan" permission set to any users who need access to Flosum Scan features. This is a one-time setup step and does not need to be repeated on subsequent upgrades, unless new users are added. From this point, whenever you upgrade, you only have to add permissions to new Flosum Scan users. All existing users continue to have permissions.



Launch Flosum Scan

1. Open Flosum DevOps, and click the nine dots in the upper right corner of the screen to open the App Launcher.

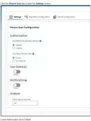


2. Enter Flosum Scan in the Search box and click it when it appears in the list.
3. The Flosum Scan application opens, displaying a list of your branches.

Configure Flosum Scan

Cloud Settings

1. Click the **Flosum Scan** tab to open the **Settings** screen.



Flosum Scan Configuration

Authorization

Use default SonarQube instance

● Default
○ Custom

Use Cloud Flosum Scan

● Cloud
○ On-Premise

Use Gateway

Disable

Notifications

Disable

Analyse

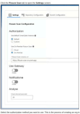
Check interval (seconds)

20

2. Leave Authorization set to Default.
   Note: Authentication is not used between your Flosum Salesforce org and Flosum Scan. Flosum Scan cloud only allows requests from Salesforce IP addresses. A list of IP addresses to whitelist is available. This method is used instead of authorization.
3. Click the radio button beside **Cloud**.
4. Leave Gateway disabled.
5. Click the toggle if you want emails to be sent to the branch or repository owner once the analysis process is completed.
6. Enter the number of seconds you want Analyse to pause the system between scans. See Analyse for more information.
7. Click **Save**.

On-Premise Settings

1. Click the **Flosum Scan** tab to open the **Settings** screen.



Flosum Scan Configuration

Authorization

Use default SonarQube instance

● Default
○ Custom

Use On-Premise Flosum Scan

○ Cloud
● On-Premise

*Flosum Scan instance url

https://flosum-scan-on-prem.app

Use Gateway

Disable

Notifications

Disable

Analyse

Check interval (seconds)

20

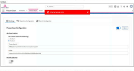
2. Select the authorization method you want to use. This is the process of creating an org in your SonarQube instance. There are three authorization methods to choose from:
   - Default—this method connects your Flosum org to the default Flosum SonarQube instance. This authorization data is stored within the Node.js application using environment variables. For on-premise instances, you do not have access to the Flosum SonarQube instance. The Default option uses credentials that you set in the Flosum Scan environment variables.
   - Custom—this method allows the use of different SonarQube instances. To perform a custom authorization, you must provide:
     - SonarQube instance URL
     - Authorization token—token is generated using your OAuth 2.0 session ID. Every time you generate a token, you have to log in, agree with listed permissions, and manually set the generated token.
       Note: Credentials for the customer's SonarQube instance are stored in a protected custom setting in Salesforce.
   - Client Credentials Flow (located on the Flosum DevOps Settings tab)—this method eliminates the need for manual interaction with OAuth tokens. With Flosum DevOps, when you create connected apps on your DevOps orgs and enable Client Credentials Flow in Settings, you automatically enable Client Credentials Flow on your connected app settings (including Flosum Scan). This gives you the ability to request access tokens using client ID and client secret instead of session ID. See Client Credentials Flow to learn more.
3. Click the radio button beside **On-Premise**.
4. Enter your Flosum Scan instance URL.
5. Leave Gateway disabled.
6. Click the toggle if you want emails to be sent to the branch or repository owner once the analysis process is completed.
7. Enter the number of seconds you want Analyse to pause the system between scans. See Analyse for more information.
8. Click **Save**.

Authorization Results

Once you click Save, the system immediately sends a request to verify the accuracy of the provided authorization data.

Possible results are:

- Successful Verification—if the data is correct, it will be securely saved in a protected custom setting.
- Unsuccessful Verification—if the data is incorrect, the authorization process halts, retaining the previously stored credentials.
- Cannot Connect to Custom SonarQube Instance—indicate an instance when SonarQube integration fails due to an Internal Server Error as shown below.



When using Custom - SonarQube URL, the call originates from your Salesforce Org and tries to reach your SonarQube instance. Since your SonarQube is not publicly accessible, you receive an internal Salesforce server error 500. To resolve the issue:

1. Ask your team to make SonarQube's URL public so that the Flosum call can be directed to the SonarQube website.
2. In the event that option 1 is not possible, please ask your SonarQube team to whitelist Salesforce IP's: https://help.salesforce.com/s/articleView?id=000384438&type=1 as well as the IP of Flosum Scan (18.119.118.97) to your firewall rules.

The SonarQube system automatically creates an org for any request coming from Salesforce. This automatic creation is managed by a Node.js application. The SonarQube org corresponds to the Salesforce org, and within it, there are projects set up for branches and repositories associated with Flosum.

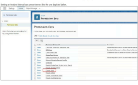
The key for the SonarQube org is the same as the Salesforce org's ID, encoded to the Z-Base-32, while the name matches the Salesforce org's name.

The Node.js application handles all communications with SonarQube. You can use the Enable/Disable toggle near the "Save" button in the upper right corner of the screen, to control the global permission to scan components by SonarQube.

Analyse

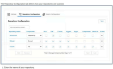
Analyse sets a seconds-long interval between scan completion checks you can use when running multiple branch/repository scans. Here, you can input the number of seconds you want the system to pause between scans. Analyse defaults to 20 seconds, but you can customize the setting to meet your needs. Flosum recommends a minimum setting of 60 seconds. See Proactive Alert Monitoring: Async Apex Execution Limit for more information.

Setting an Analyse interval can prevent errors like the one depicted below.



Repository Configuration

The Repository Configuration tab defines how your repositories are scanned.



Repository Name	Components	Aura	LWC	Classes	Triggers	Pages	Components	Select All	Action
Production	Repository	☐	☑	☐	☐	☐	☐	☐	✕
Default	Branch	☑	☑	☑	☑	☐	☐	☐	✕
Flosum	All	☑	☑	☑	☑	☑	☑	☑	✕

Total 3 changed component(s), Page 1 of 1

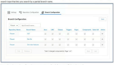
1. Enter the name of your repository.
2. Select an option from the drop-down menu in the Components column. Options are:
   - All—sets up for the repository and all the branches from this repository, aligning them to the same type of configuration. All new and existing branches will have this same configuration for scanning.
   - Repository—pertains to components only from this repository.
   - Branch—sets up all branches from this repository with the same type of configuration. All new and existing branches will adopt this same configuration for scanning.
3. Check or uncheck the box to set which items are scanned for.

Important: Repository configurations overwrite branch configuration if you select "All" or "Branch" from the Repository Configuration tab. When you choose either "Branch" or "All" from the Repository Configuration tab, then this configuration will be applicable to all the branches in the repository. If a branch has an additional configuration, it will be overridden by the repository configuration. Also, these branch configurations (under Branch Configuration) will be disabled for selecting component types (since they will be controlled from the Repository Configuration).

Branch Configuration

There are two ways to configure component types for scanning:

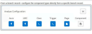
1. Using the Branch Configuration tab—select the component types you want to scan. This page displays branch records ten at a time. Two filters are also available: first, by repository, allowing you to select the desired repository to view branch records from that specific repository; and second, a search input that lets you search by a partial branch name.



Repository Name	Branch Name	Aura	LWC	Classes	Triggers	Pages	Components	Select All	Action
Flosum	SAT	☑	☑	☑	☑	☑	☑	☑	✕
Flosum	Dev-fix	☑	☑	☑	☑	☑	☑	☑	✕
Flosum	Dev-new-features	☑	☑	☑	☑	☑	☑	☑	✕

Total 3 changed component(s), Page 1 of 1

2. From a branch record—configure the component types directly from a specific branch record.



The branch configuration allows configuring existing branches for scanning. You can select types required for scanning that are supported by SonarQube. Additionally, there's an option to scan branches immediately using the action button however, for branches that do not have at least one selected type, this button will be disabled.

The branch record configuration component includes the same options that are present on the branch configuration tab.

The branch configuration is dependent on the repository configuration. When a repository has designated types for scanning and has selected components set to scan either "All" or "Branch", the branch configuration is overridden and shows the configuration from the associated repository.

Run a Flosum Scan

There are several ways to launch an analysis on the Flosum Scan:

- From the branch/repository configuration tab
- From the branch record
- On component changes

To prevent running the analysis for frequent changes in repository components, the launch analysis is postponed for 3 minutes after the previous component change. The logic checks for any updates within those 3 minutes, and if there are any, the analysis will be postponed for another 3 minutes. This pattern will continue until 3 minutes have passed since the last change.

Another scenario is when an analysis is launched while a SonarQube project already has an analysis in progress. In this case, SonarQube will return an error: "Another SonarQube analysis is already in progress for this project". Logic is in place to postpone the analysis until the current one is completed.

Flosum will always send all components from the branch/repository for each analysis because SonarQube does not support partial scans of components. Each new analysis overwrites the previous one.

Flosum Scan **initiates branch scanning automatically once components are inserted into a branch** (e.g., from a snapshot), after components within the branch are updated, and after components are deleted from the branch.

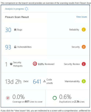
The code scanned by the Default instance will be stored in the Flosum SonarQube instance and Flosum will have access to this code. If you do not want Flosum to access your code, please connect to your SonarQube instance using the Custom authorization.

Viewing Scan Results

After a successful Flosum Scan scan, you can view the results across multiple pages, including an overview result, an issues list, and an issue details screen.

Overview Result Screen

This component on the branch record provides an overview of the scanning results from Flosum Scan.


Analysis in progress

Flosum Scan Result — View issues

30 Bugs — Reliability C

93 Vulnerabilities — Security D

1 Security Hotspots — 0.0% Reviewed — Security Review E

13d 2h Debt — 641 Code smells — Maintainability B

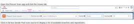
0.0% Coverage on 807 Lines to cover — 0.6% Duplications on 2.3k Lines

If you click the "View issues" link, you are redirected to a screen with a comprehensive, unfiltered list of all detected issues. The number next to a specific type of issue is also clickable, redirecting you to a detailed issues page filtered by the selected issue type.

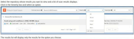
Note: If your Flosum Scan instance is cloud-based, scanning and analysis runs in a specific order. You have to ensure job processing is complete for the initial commit before running another, otherwise if you recommit the metadata it takes the latest metadata and displays results based on that. The time taken to process a commit depends on AWS Batch Computing, the duration depends on the AWS Batch resource and number of metadata components committed. A real-time spinner at the top of the component indicates a job is still in progress.

Issues List

1. Open the Flosum Scan app and click the Issues tab.



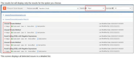
2. Click in the box beside Find scan source to display a list of available branches and repositories.
   Note: You can only view repository scan results from the Issues tab.
3. Select the repository whose results you want to view and a list of scan results displays.
4. Click in the Severity box and select an option.



classes/DomainService.cls

Avoid using multi conditions in SOQL WHERE clause

5. The results list will display only the results for the option you choose.



classes/DomainAutomation.cls

classes/DomainAutomationTests.cls

Unused Private Method — Major — Code smell

Unused Private Method — Major — Code smell

Avoid Calling SOQL with Negative Expressions — Major — Code smell

Unused Private Method — Major — Code smell

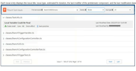
Avoid Calling SOQL with Negative Expressions — Major — Code smell

This screen displays all detected issues in a detailed list.

Filters at the top of the screen let you search for specific Branch/Repository scan results and categorize issues by type: Bug, Vulnerability, or Code Smell. You can also search issues based on branch name or repository name.

A maximum of 20 search results display at a time. The issues are displayed in batches of 100 per page, with pagination options available at the bottom of the page.

Each issue entry displays the issue title, issue type, estimated fix duration, the last modifier of the problematic component, and the last modification date.



classes/TestUtils.cls

Local Variable Could Be Final — Code smell — Line - 46 — 5min effort — bad-practice

Last Modified Date: 2023/07/25 12:41:08

Last Modified By: [redacted]

classes/BranchTriggerHandler.cls

classes/BranchConfigurationController.cls

classes/BranchUtil.cls

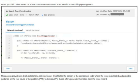
classes/BranchConfigurationControllerTest.cls

classes/BranchTriggerTest.cls

Issue 1 - 100 of 1316, Page 1 of 14

Issue Details

When you click "View issues" or a blue number on the Flosum Scan Results screen this popup appears.


At Least One Constructor — Code smell — Line - 1 — 10min effort — bad-practice

Last Modified Date: 2023/08/02 01:49:29

Last Modified By: [redacted]

Flosum

classes/BranchTriggerHandler.cls

```
public with sharing class BranchTriggerHandler {

    public static void afterUpdate(Map<Id, Flosum__Branch__c> newMap, Map<Id, Flosum__Branch__c> oldMap) {
        FlosumScanService.sendNotificationMessage(getBranchesIdsOnCompleteAnalysis(newMap, oldMap));
    }

    public static void beforeInsert(List<Flosum__Branch__c> branches) {
        Set<Id> repositoryIds = new Set<Id>();

        for (Flosum__Branch__c branch : branches) {
```

This pop-up provides in-depth details for a selected issue. It highlights the portion of the component code where the issue is detected and provides guidance on the root cause of the problem ("Why is the issue?"). It also offers general information from the issue record.

You can navigate between issues using the "next" or "previous" pagination options, which cover the 100 issues displayed on the Issues page.

Links are available to redirect you to the related branch/repository by name or to the component by component name.

Quality Gate Workaround

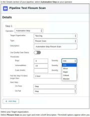
There is a manual workaround to use SonarQube scan results as Quality Gates:

1. Establish a procedure to trigger pipelines at the desired stage in your development process.
2. Create the branch that will trigger SonarQube and Pipeline operations.
3. Create the pipeline, making sure the peer review step is the first operation. The order should be similar to the following:
   - Step 1: Peer Review
   - On Pass: Step 2
   - On Fail: Stop
   - Step 2: Validation/Deploy
4. Once the pipeline is created, associate this with the branch that will trigger the operations.
5. Configure SonarQube for the specific branch.
6. Once metadata is merged into the branch from step 4, this will trigger the SonarQube and Pipeline operations.
7. The person designated to perform the peer review needs to check results from SonarQube and approve or reject Peer Review.

Scan Automation on a Pipeline

The Flosum Scan Automation pipeline step initiates a scan to run on your branch. It scans your branch for defects and vulnerabilities and returns these results as part of your pipeline process. You can define thresholds within the pipeline that will trigger failure if exceeded.
Note: You must be running Flosum Scan v1.23.

1. In the Details section of your pipeline, select **Automation Step** as your operator.


Pipeline Test Flosum Scan

Details

Step 1:

Operation: Automation Step

Target Organization: Test Org

Type: Flosum Scan

Description: Automation Step Flosum Scan

Use Quality Gate Status:

Thresholds:

Bugs: 9 — Severity: Info

Vulnerabilities: 15 — Severity:

Code Smells: — Severity:

Fail this Step if it takes longer than: 1 hour

Next Step:

On Pass: Stop

On Fail: Stop

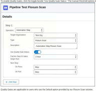
2. Select your Target organization.
3. Select **Flosum Scan** as your type and enter a brief description. Threshold options appear when you select Flosum Scan.
4. Set the thresholds you want to use to define failure. Thresholds are specific metrics you assign that will trigger pipeline failure if exceeded.
   - Bugs - number of bugs the scan can encounter before the process fails.
   - Vulnerabilities - number of instances where potential security risks have been encountered that can occur before the process fails. This is the number of vulnerabilities returned from SonarQube in the scan results.
5. Specify the duration for which you want the system to wait before considering the step a failure.

Quality Gate

If you choose to enable Quality Gate, the parameters of quantity and severity for Bugs, Vulnerability and Code Smells are not displayed. Instead, your pipeline step now looks at the severity of a bug/code smell rather than the actual number of bugs/code smells. You must update to DevOps v3.254 to use the Quality Gates feature.

Note: To use this feature, you must upgrade to Flosum Scan v1.35.

To enable Quality Gates, click the toggle beside "Use Quality Gate Status." The manual threshold options do not display if Quality Gates are enabled.


Pipeline Test Flosum Scan

Details

Step 1:

Operation: Automation Step

Target Organization: Test Org

Type: Flosum Scan

Description: Automation Step Flosum Scan

Use Quality Gate Status:

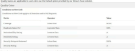
Fail this Step if it takes longer than: 1 hour

Next Step:

On Pass: Stop

On Fail: Stop

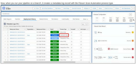
Quality Gates are applicable to users who use the Default option provided by our Flosum Scan solution.


Quality Gates

Conditions on New Code

Conditions on New Code apply to all branches and to Pull Requests.

Metric	Operator	Value
Coverage	is less than	80.0%
Duplicated Lines (%)	is greater than	3.0%
Maintainability Rating	is worse than	A
Reliability Rating	is worse than	A
Security Hotspots Reviewed	is less than	100%
Security Rating	is worse than	A

Now, when you run your pipeline on a branch, it creates a metadata log record with the Flosum Scan Automation process type.